

Authentication and Authorization Model

Security Policy & Governance Specification

The system uses authentication to verify the identity of users and authorization to control what authenticated users are allowed to access or perform.

Authorization decisions are based on the user's assigned role and organizational scope. All authorization checks are enforced on the backend and must not depend only on Flutter UI restrictions.

1. Authentication

All users must authenticate before accessing protected system resources.

The authentication mechanism shall:

- Verify user credentials before issuing an authenticated session.
- Use secure password hashing for stored passwords.
- Use access tokens for authenticated API requests.
- Reject invalid or expired tokens.
- Support token/session revocation where required.
- Prevent passwords, tokens, and other authentication secrets from being stored in application logs.
- Ensure protected APIs cannot be accessed without valid authentication.

2. Authorization

After successful authentication, the backend determines whether the user is authorized to perform the requested action.

Authorization is based on:

User → Role → Permission → Organizational Scope → Resource

A user must satisfy both the required permission and the applicable organizational scope before access is granted.

Asset Administrator

Responsible for asset registry and asset lifecycle operations.

Authorized to:

- Manage locations and asset categories.
- Create and update assets.
- Import assets.
- Transfer assets.
- Manage custody assignments.
- Retire assets through the approved workflow.
- View procurement references.
- View maintenance and service history.

Note: The role does not automatically grant permission to modify invoices or financial records.

Procurement / Finance Viewer

Responsible for procurement and financial information.

Authorized to:

- View asset information.
- Create and update suppliers.
- Create and update purchase orders.
- Create and update invoice/receipt metadata.
- Manage warranty information.
- View asset cost and financial references.

Not authorized to:

- Transfer assets.
- Change asset custody.
- Modify general asset information.
- Modify maintenance records.
- Retire assets.

Custodian / Department Manager

Responsible for assets within the user's organizational scope.

Authorized to:

- View assets within the assigned scope.
- View relevant asset information.
- Confirm asset assignment/custody.
- Report or update asset condition.
- View maintenance status.

Not authorized to:

- Access invoices or sensitive financial information.
- Modify suppliers or purchase orders.
- Retire assets.
- Access assets outside the assigned organizational scope.

Maintenance Technician

Responsible for maintenance operations.

Authorized to:

- View assets required for maintenance.
- View work orders.
- Update assigned work orders.
- Record service activities.
- Record parts used.
- Record downtime.
- Record service outcomes.
- Complete work orders.

Not authorized to:

- Access invoices or unrelated financial information.
- Modify general asset registry information.
- Transfer assets.
- Retire assets.

Auditor

The Auditor is a read-only role.

Authorized to:

- Read asset inventory.
- Read financial references according to assigned scope.
- Read custody and transfer history.
- Read maintenance history.